

BHSI BROKER PORTAL

Business Architecture Requirements & Executive Decision Document

BHSI Business Vision | Coforge Architecture & Delivery Enablement

Small Commercial Headless Experience with Duck Creek Core Integration

Document Owner	Manivannan Nandagopalan, Principal Architect
Version	1.0 - Consolidated Working Draft
Date	September 24, 2026
Status	For Business, Architecture, Security, and Delivery Review

Document Purpose Define the business, functional, integration, security, data, AI, and non-functional requirements for four major Broker Portal modules: Auth0 SSO and user access, AI-powered Underwriting Guidelines, Moratorium Management, and Small Commercial broker intake using Duck Creek as the headless core system.

Document Control

Version	Date	Owner	Change Summary
1.0	Sep 24, 2026	Manivannan Nandagopalan	Consolidated requirements for all four major modules.

Review and Approval

Review Area	Recommended Approver	Decision
Business scope	Product Owner / Business Operations Leadership	Pending
Identity and security	IAM and Security Architecture	Pending
Underwriting content and AI	Underwriting Leadership / AI Governance	Pending
Moratorium controls	Business Operations / Underwriting Governance	Pending
Duck Creek integration	Duck Creek Product and Integration Owners	Pending
Delivery and operations	Engineering, QA, SRE, Support	Pending

Table of Contents

Document Control 2

Review and Approval 2

Table of Contents 2

1. Executive Summary 5

1.1 Leadership Decision Summary 5

1.2 Major Modules 5

1.3 Terminology Clarification..... 6

2. Business Context and Objectives 6

2.1 Business Context 6

2.2 Business Objectives..... 6

2.3 Proposed Success Measures 6

3. Scope and Stakeholders 7

3.1 In Scope 7

3.2 Out of Scope Unless Separately Approved	7
3.3 Stakeholders and Personas	7
4. Solution Principles and Architecture	8
4.1 Architecture Principles	8
4.2 Industry Standards and Control Framework	8
4.3 Logical Architecture	9
4.4 Critical Architecture Decisions	9
5. Module 1 - Auth0 SSO and User Access	10
5.1 Objective.....	10
5.2 Business Architecture Controls.....	10
5.3 Business Requirements.....	10
5.4 Functional Flow	11
5.5 Roles	11
5.6 Acceptance Criteria	11
6. Module 2 - AI Underwriting Guidelines	12
6.1 Objective.....	12
6.2 Business Architecture Controls.....	12
6.3 Content Lifecycle.....	12
6.4 Business and Functional Requirements.....	12
6.5 Answer Experience.....	13
6.6 AI Quality and Governance	13
7. Module 3 - Moratorium Management	14
7.1 Objective.....	14
7.2 Business Architecture Controls.....	14
7.3 Moratorium Scope and Applicability	14
7.4 Requirements	15
7.5 Moratorium Lifecycle	16
7.6 Conflict and Precedence Rules	16
8. Module 4 - Small Commercial Headless Broker Portal	17
8.1 Objective.....	17
8.2 Business Architecture Controls.....	17
8.3 End-to-End Broker Journey	17
8.4 Functional Requirements	18
8.5 Product and Risk Data	19
8.6 Headless Integration Principles	20
9. Cross-Module Requirements	20

9.1 User Experience.....20

9.2 Notifications.....20

9.3 Audit20

10. Data, Integration, and API Requirements.....21

10.1 Core Data Domains21

10.2 Source-of-Truth Direction21

10.3 API Standards22

11. Non-Functional Requirements22

12. Reporting, Audit, and Operations.....23

12.1 Business Reporting23

12.2 Operational Dashboards23

12.3 Support Requirements23

13. Acceptance, Traceability, and Delivery.....23

13.1 Definition of Ready23

13.2 Definition of Done24

13.3 Recommended Delivery Increments.....24

14. Assumptions, Dependencies, Risks, and Open Decisions24

14.1 Key Assumptions24

14.2 Dependencies and Risks25

14.3 Open Decisions25

Appendix A - Glossary26

Appendix B - Source Notes27

1. Executive Summary

The Broker Portal will be the primary digital system of engagement for external brokers and authorized internal users. It will provide secure access, guided Small Commercial intake, AI-assisted access to approved underwriting guidelines, and centralized management of temporary insurance moratoriums affecting specified new business, renewal, endorsement, quote, bind, issue, or coverage activity. Duck Creek will remain the backend core platform and system of record for insurance transactions, subject to confirmation of available products, APIs, service contracts, authentication patterns, and operational constraints.

Target Outcome A secure, role-aware, API-driven portal that improves external broker experience while keeping underwriting decisions, production controls, transaction integrity, and auditability under enterprise governance.

1.1 Leadership Decision Summary

Leadership Priority	Decision / Direction	Business Value
Experience ownership	Broker Portal is the broker-facing system of engagement; Duck Creek remains the authoritative transaction system.	Separates channel innovation from core-platform stability.
Identity and trust	Auth0 provides federation and authentication, with BHSI-controlled authorization and lifecycle governance.	Scalable onboarding with enforceable least privilege.
Underwriting intelligence	Guidance is retrieval-grounded, citation-backed, entitlement-aware, and subject to human escalation.	Improves speed without delegating underwriting authority to AI.
Production control	Moratoriums use deterministic rules, delegated authority, fail-safe behavior, and reconciliation.	Enables rapid, governed response to catastrophe and appetite events.
Delivery model	Release incrementally with contract-first APIs, measurable quality gates, and production-readiness evidence.	Reduces dependency risk and accelerates controlled value.

1.2 Major Modules

Module	Business Outcome	Primary Users
1. Auth0 SSO and User Access	Securely authenticate external brokers and internal users; manage identity, roles, agencies, and provisioning.	External brokers, broker administrators, internal users, IAM/support
2. AI Underwriting Guidelines	Allow users to ask questions and receive grounded answers from approved guideline documents with citations.	Brokers, underwriters, guideline administrators
3. Moratorium Management	Temporarily suspend specified new business, renewals, endorsements, quoting, binding, policy issuance, or selected coverages by product, geography, peril, agency, risk class, and effective period.	Business Operations, underwriting leadership, administrators

Module	Business Outcome	Primary Users
4. Small Commercial Headless Portal	Capture the complete broker intake and submission journey while Duck Creek provides core policy, rating, and transaction capabilities.	External brokers, underwriters, operations, support

1.3 Terminology Clarification

Moratorium is the standard insurance term used throughout this document. It means a temporary, formally authorized suspension of writing or processing specified insurance business for a defined scope and period. A moratorium may apply to new business, renewals, endorsements, quoting, binding, policy issuance, or selected coverages. Typical examples include a “Florida Homeowners Moratorium due to Hurricane” and an “Underwriting Moratorium for wildfire-exposed regions.” A moratorium does not automatically cancel or alter existing coverage; the treatment of in-force policies and transactions already in progress must be explicitly defined.

2. Business Context and Objectives

2.1 Business Context

- External brokers require a scalable authentication approach without creating and maintaining every broker identity in the internal enterprise directory.
- Underwriting guidelines exist across Word, PDF, and spreadsheet-based content and must be secured, searchable, versioned, and presented consistently.
- Business Operations needs the ability to react quickly to catastrophe events, regulatory changes, appetite changes, agency restrictions, capacity constraints, or other production conditions.
- The Broker Portal must handle end-to-end broker intake for Small Commercial business while integrating with Duck Creek as the backend core platform.

2.2 Business Objectives

- Provide a modern and consistent experience for external brokers.
- Reduce manual identity administration and accelerate broker onboarding.
- Reduce time spent searching guideline documents and asking repetitive underwriting questions.
- Consistently suspend prohibited insurance-writing activity when an active moratorium applies.
- Improve submission completeness and data quality before sending transactions to Duck Creek.
- Create a modular foundation for additional products, agencies, states, and workflows.
- Maintain security, evidence, traceability, and operational supportability across all modules.

2.3 Proposed Success Measures

Governance Note Targets below are proposed measures requiring business and platform approval. They are not committed service levels.

Measure	Proposed Direction
---------	--------------------

Measure	Proposed Direction
Access	Approved broker users can authenticate and access only their authorized organization and functions.
Answer quality	AI answers include approved source citations and decline when evidence is insufficient.
Control enforcement	Active moratoriums are evaluated before affected insurance activities, producing auditable Allow, Suspend, or Refer outcomes.
Submission quality	Required data and documents are validated before submission to Duck Creek.
Operational readiness	Support teams can monitor integrations, retries, failures, security events, and content/control changes.

3. Scope and Stakeholders

3.1 In Scope

- Auth0-based authentication, federation, MFA policy integration, and secure session handling.
- External broker organization onboarding, invitation, provisioning, role assignment, deactivation, and access review.
- Approved underwriting document ingestion, indexing, retrieval, AI question answering, citations, feedback, and administration.
- Moratorium creation, approval, activation, evaluation, notification, expiry, override governance, and audit.
- Small Commercial broker intake, draft/save/resume, eligibility, document collection, submission, quote/status visibility, referral, and downstream Duck Creek integration.
- Shared dashboard, notification, reporting, audit, observability, configuration, and administration capabilities.

3.2 Out of Scope Unless Separately Approved

- Replacing Duck Creek as the policy administration or rating system.
- Allowing generative AI to make final underwriting, pricing, bind, issue, or compliance decisions.
- Claims intake and servicing, billing servicing, endorsements, renewals, cancellations, and reinstatements beyond explicitly approved releases.
- Unrestricted self-service changes to production rules or guideline content without approval and audit controls.
- Assuming Duck Creek interfaces or capabilities before contracts and environment connectivity are confirmed.

3.3 Stakeholders and Personas

Persona	Key Needs
External Broker	Secure login, guided intake, guideline answers, document upload, submission/quote/status visibility.
Broker Administrator	Invite and manage broker users within authorized agency scope.
Underwriter	Review referrals, access guidelines, view submission details, and communicate status.

Persona	Key Needs
Business Operations Leader	Create and govern moratoriums/holds with rapid activation and clear impact.
Guideline Administrator	Upload, classify, approve, publish, retire, and monitor guideline content.
System Administrator	Manage configuration and support without bypassing separation of duties.
Security / IAM	Control federation, MFA, roles, session policies, audit, and access reviews.
Support / SRE	Monitor health, failures, retries, reconciliation, and incidents.

4. Solution Principles and Architecture

4.1 Architecture Principles

- System of Engagement vs. System of Record: the portal owns the user experience and portal workflow; Duck Creek owns approved core insurance records and transactions.
- API-first headless integration: the portal must not depend on Duck Creek user interfaces for broker journeys.
- Server-side authorization: the API enforces access decisions; browser route guards are usability controls only.
- Grounded AI: answers must be retrieved from approved content, include source references, and avoid unsupported responses.
- Policy-driven controls: moratorium evaluation is deterministic, versioned, explainable, and auditable.
- Loose coupling: use integration adapters, asynchronous processing, idempotency, retries, reconciliation, and correlation IDs.
- Modular delivery: begin with clear module boundaries that can evolve based on measured scale and operational needs.

4.2 Industry Standards and Control Framework

The target architecture shall be governed through a pragmatic control baseline aligned to widely adopted enterprise standards. Applicability and evidence requirements will be confirmed with BHSI risk, legal, compliance, security, data, and internal audit stakeholders.

- **Security and privacy:** NIST Cybersecurity Framework, NIST SP 800-53 control concepts, ISO/IEC 27001, least privilege, zero-trust principles, privacy-by-design, secure SDLC, and OWASP ASVS/API Security controls.
- **Identity:** OAuth 2.0, OpenID Connect, SAML 2.0 where required, phishing-resistant MFA where supported, lifecycle governance, periodic access certification, and segregation of duties.
- **Insurance interoperability:** ACORD-aligned data semantics and forms where applicable, canonical mappings, producer/agency authority validation, and state/product effective-dating.
- **Accessibility and experience:** WCAG 2.2 AA target, responsive design, keyboard navigation, clear error recovery, and plain-language broker communications.
- **AI governance:** NIST AI RMF-aligned risk controls, approved-source grounding, evaluation baselines, human oversight, prompt-injection defenses, model/configuration change control, monitoring, and rollback.
- **Resilience and operations:** SRE service objectives, observability, capacity and catastrophe-volume testing, business continuity, disaster recovery, incident management, and immutable audit evidence.

- **Delivery assurance:** API-first contracts, automated quality gates, software composition analysis, threat modeling, performance testing, release traceability, and production-readiness reviews.

4.3 Logical Architecture

Layer	Components
Experience	Angular Broker Portal, responsive UI, accessibility, chatbot, administration screens
Security	Auth0, external broker IdPs, enterprise IdP, token validation, portal authorization
Application	ASP.NET Core APIs, workflow orchestration, validation, policy evaluation, audit
AI and Content	Document ingestion, extraction, chunking, search/vector index, model gateway, citations, safety controls
Integration	Duck Creek adapters for user administration, party/insured, product, policy, rating, producer/agency, documents, and transactions
Data and Operations	SQL Server, approved document/object storage, outbox/queue, telemetry, reporting, support tools

4.4 Critical Architecture Decisions

Decision	Required Outcome
Duck Creek interfaces	Confirm products, API/service contracts, authentication, rate limits, environments, error models, and transaction ownership.
Identity source of truth	Confirm ownership of identity, broker profile, agency relationships, product entitlements, and Duck Creek access.
AI platform	Select approved model, retrieval/search, content storage, moderation, logging, and evaluation services.
Moratorium authority	Confirm where the authoritative moratorium is maintained, how affected insurance activities and scope are represented, how activation and lifting are synchronized to Duck Creek, and how consistent enforcement is guaranteed.
Hosting and operations	Confirm cloud/on-premise hosting, secrets, messaging, monitoring, CI/CD, backup, DR, and support model.

5. Module 1 - Auth0 SSO and User Access

5.1 Objective

Provide secure authentication for external brokers and internal users through Auth0, with organization-aware routing, role-based access, controlled provisioning, and integration with applicable Duck Creek user administration requirements.

5.2 Business Architecture Controls

- **Identity assurance:** Define assurance levels by persona and transaction risk; apply adaptive or step-up authentication for privileged administration, sensitive data access, and bind/issue actions.
- **Organization isolation:** Enforce agency and branch boundaries in every API, query, export, notification, cache, and support workflow; prohibit reliance on client-side filtering.
- **Lifecycle governance:** Support invitation expiry, duplicate detection, joiner-mover-leaver processes, periodic access certification, dormant-account handling, emergency revocation, and reconciliation across Auth0, portal, and Duck Creek records.
- **Privileged access:** Separate user administration, entitlement approval, support impersonation, and audit review; require reason capture, time-bound privilege, and immutable evidence.
- **Federation resilience:** Define broker-domain discovery, IdP outage behavior, break-glass support, account recovery, token/session revocation, and safe handling of partially provisioned users.

5.3 Business Requirements

ID	Requirement
BR-AUTH-001	The portal shall allow approved external brokers to sign in through an Auth0-mediated login experience.
BR-AUTH-002	The solution shall support federation with approved broker identity providers using supported enterprise standards and policies.
BR-AUTH-003	The solution shall support internal users through the approved enterprise identity provider.
BR-AUTH-004	Each external user shall be associated with an approved broker organization, agency, or branch context.
BR-AUTH-005	Access shall be governed by roles, permissions, product entitlements, agency scope, and resource ownership.
BR-AUTH-006	Authorized broker administrators shall invite, view, update, deactivate, and request role changes for users within their permitted scope.
BR-AUTH-007	User provisioning shall create or synchronize records in Auth0, the portal, and Duck Creek where required by confirmed integration contracts.
BR-AUTH-008	The system shall support MFA, account lockout, session timeout, logout, and access revocation according to approved security policy.
BR-AUTH-009	All identity lifecycle and privileged access events shall be auditable.

ID	Requirement
BR-AUTH-010	Failed or partial provisioning shall be visible to support teams and recoverable through retry or reconciliation.

5.4 Functional Flow

1. User enters the portal or follows an approved deep link.
2. Portal initiates the Auth0 authorization flow using the approved browser application pattern.
3. Auth0 routes the user to the correct organization identity provider or approved credential flow.
4. Portal API validates the access token and resolves the mapped portal user, organization, roles, permissions, and entitlements.
5. Portal permits or denies each API operation using server-side authorization.
6. Audit and security telemetry capture the outcome without logging credentials or tokens.

5.5 Roles

Role	Illustrative Access
Broker User	Own/agency-allowed submissions, guideline assistant, documents, status, notifications.
Broker Administrator	Broker user invitations and lifecycle administration within assigned organization scope.
Underwriter	Referral and underwriting views based on assigned products/territories.
Operations User	Operational dashboards and approved control functions.
Business Operations Leader	Moratorium approval/activation based on delegated authority.
Guideline Administrator	Content lifecycle management.
System/Support Administrator	Configuration and support actions with strong audit and separation of duties.

5.6 Acceptance Criteria

- An approved external broker can authenticate and reaches only the organization and functions assigned to that user.
- An unauthorized, disabled, expired, or unmapped identity is denied with a safe error and support correlation reference.
- A broker administrator cannot manage users outside the administrator's authorized organization scope.
- Provisioning failures do not create invisible or inconsistent access; status and remediation are available to authorized support users.
- Logout and access revocation behavior follows approved policy across portal sessions and dependent systems.

6. Module 2 - AI Underwriting Guidelines

6.1 Objective

Provide a secure conversational assistant that answers broker and underwriter questions using only approved underwriting guideline content. The assistant must show citations, respect user entitlements, preserve version context, and clearly state when approved evidence does not support an answer.

6.2 Business Architecture Controls

- **Authoritative content:** Assign accountable owners, reviewers, effective dates, jurisdiction/product applicability, supersession rules, emergency correction procedures, and legal-hold retention.
- **Retrieval security:** Apply entitlement filters before retrieval and generation; prevent cross-agency, cross-product, draft, retired, or restricted-content leakage.
- **Answer governance:** Require citation-backed responses, explicit applicability context, bounded prompts, refusal for insufficient evidence, and escalation to an accountable underwriter or content owner.
- **Model risk management:** Maintain representative evaluation sets, release thresholds, drift and quality monitoring, red-team tests, incident response, configuration lineage, and rollback capability.
- **Records and privacy:** Classify prompts, responses, feedback, and telemetry; minimize personal or confidential data; define retention, deletion, review access, and audit evidence.

6.3 Content Lifecycle

7. Upload and malware-scan approved source documents.
8. Capture metadata including product, state, class, coverage, effective date, version, owner, sensitivity, and approval status.
9. Extract and normalize content; record extraction quality and unsupported elements.
10. Create searchable chunks and indexes under the approved AI architecture.
11. Review and approve content before publication.
12. Publish effective versions and retire or supersede outdated versions without losing audit history.
13. Re-index changes and validate representative questions before release.

6.4 Business and Functional Requirements

ID	Requirement
BR-AI-001	Authorized users shall upload PDF, Word, spreadsheet, and other approved guideline formats.
BR-AI-002	Content shall not be available to end users until it passes defined review and publication controls.
BR-AI-003	Users shall ask natural-language questions and optionally filter by product, state, class, coverage, or effective date.
BR-AI-004	Answers shall be grounded in content the user is authorized to access.
BR-AI-005	Every substantive answer shall show document title, relevant section/page or equivalent locator, version, and effective date when available.

ID	Requirement
BR-AI-006	When evidence is missing, conflicting, outdated, or ambiguous, the assistant shall state the limitation and direct the user to an approved escalation path.
BR-AI-007	The assistant shall not make final underwriting, pricing, bind, issue, legal, or regulatory decisions.
BR-AI-008	Users shall provide feedback on answer usefulness, accuracy concerns, and missing content.
BR-AI-009	Authorized administrators shall publish, supersede, retire, and re-index content with full audit history.
BR-AI-010	The system shall retain an approved, privacy-safe record of questions, retrieved sources, model response, feedback, and correlation metadata subject to retention policy.
BR-AI-011	The portal shall defend against prompt injection, unauthorized retrieval, sensitive-data disclosure, and instructions embedded in documents.
BR-AI-012	The assistant shall display a clear notice that responses are informational and must follow authoritative underwriting procedures.

6.5 Answer Experience

Response Element	Requirement
Answer	Concise, direct response based on retrieved approved evidence.
Evidence	Citations that link back to accessible source content and identify the applicable version.
Applicability	Product/state/class/effective-date context used for the answer.
Confidence handling	No invented numeric score; explain missing, conflicting, or weak evidence.
Next action	Escalation to underwriting or content owner when a definitive answer is unavailable.
Feedback	Useful/not useful, issue category, optional comments.

6.6 AI Quality and Governance

- Maintain a curated evaluation set covering eligibility, appetite, exclusions, required information, limits, and geographic questions.
- Measure citation correctness, answer groundedness, retrieval relevance, refusal quality, security boundary enforcement, and latency.

- Require human approval for prompt, model, retrieval, ranking, chunking, or content-policy changes that materially affect answers.
- Support rollback to a previously approved configuration and index.
- Do not train public or external models on confidential portal content unless explicitly approved by governance and contract.

7. Module 3 - Moratorium Management

7.1 Objective

Enable authorized underwriting and business leaders to establish, approve, communicate, enforce, and lift temporary moratoriums that suspend specified insurance-writing activities. A moratorium may be invoked for catastrophe events, impending severe weather, wildfire exposure, regulatory direction, capacity constraints, material system incidents, or other approved underwriting conditions. The solution shall precisely identify the affected line of business, product, state or territory, peril, coverage, transaction type, effective date and time, and permitted exceptions.

7.2 Business Architecture Controls

- **Temporary suspension:** Every moratorium shall have a defined business reason, effective start, review cadence, and expiry or formal lifting decision. Open-ended moratoriums require periodic reauthorization.
- **Insurance transaction scope:** The creator shall explicitly select whether the moratorium applies to new business, renewals, endorsements, quoting, binding, policy issuance, adding or increasing coverage, or another approved activity.
- **Risk and territorial scope:** Applicability may be defined by line of business, product, state, county, ZIP code, catastrophe zone, distance radius, peril, coverage, class, agency, producer, or approved combinations.
- **Delegated authority:** Only authorized roles may draft, approve, activate, modify, lift, or grant exceptions. Severe or broad moratoriums may require dual approval and legal, compliance, or catastrophe-management consultation.
- **Existing business treatment:** The rule shall distinguish new or changed exposure from in-force coverage. Cancellation, nonrenewal, reduction of existing coverage, and regulatory notices remain governed by applicable policy terms and approved procedures.
- **Consistent enforcement:** The portal and Duck Creek shall apply the same effective-dated decision at all required checkpoints, provide an explainable reason, prevent unauthorized bypass, and reconcile discrepancies.
- **Communication and audit:** Activation, extension, narrowing, exceptions, and lifting shall generate approved internal and broker communications and retain immutable decision evidence.

7.3 Moratorium Scope and Applicability

Scope Dimension	Insurance Requirement / Examples
Business activity	New business, renewals, endorsements, quoting, binding, policy issuance, adding or increasing coverage, or another explicitly approved transaction.
Line / product	Homeowners, Commercial Property, BOP, General Liability, Workers Compensation, Cyber, or another configured product.
Geography	State, county, ZIP code, catastrophe zone, coastal or wildfire zone, or an approved radius/polygon when reliable geospatial data is available.
Peril / coverage	Wind, hurricane, wildfire, flood, earthquake, property coverage, or specific coverage options and limits.

Scope Dimension	Insurance Requirement / Examples
Risk segment	Occupancy, construction, protection class, class code, exposure threshold, or another approved underwriting characteristic.
Distribution	All distribution, selected agency, branch, producer, channel, or appointment relationship when the moratorium is distribution-specific.
Effective period	Immediate or scheduled start, time zone, expiry date/time, review date, extensions, and lifting date/time.
Existing / in-flight business	Explicit treatment of drafts, submissions, quotes, pending binds, renewals, endorsements, and in-force policies that existed before activation.
Examples	“Florida Homeowners Moratorium due to Hurricane” and “Underwriting Moratorium for wildfire-exposed regions.”

7.4 Requirements

ID	Requirement
BR-MOR-001	Authorized users shall create a draft moratorium with business reason, issuing authority, affected insurance activity, scope criteria, effective period, review date, communications, and supporting evidence.
BR-MOR-002	The solution shall support approval and separation-of-duties rules based on the breadth, severity, duration, and jurisdictional impact of the moratorium.
BR-MOR-003	Authorized leadership shall activate an approved emergency moratorium immediately and document any permitted expedited approval path.
BR-MOR-004	A moratorium shall explicitly identify the affected activity: new business, renewal, endorsement, quote, bind, issue, adding or increasing coverage, or another approved transaction.
BR-MOR-005	A moratorium shall support line/product, geography, peril/coverage, risk classification, agency/producer, and approved combination criteria.
BR-MOR-006	The system shall evaluate the applicable effective-dated rule using approved priority, specificity, and conflict-resolution policy.
BR-MOR-007	The decision shall be Allow, Suspend, or Refer, with a reason code, effective period, authority, and user-safe explanation.
BR-MOR-008	The portal shall evaluate the moratorium before each affected transaction and re-evaluate when material risk, location, coverage, or effective-date data changes.
BR-MOR-	The solution shall define the treatment of existing drafts, submissions, quotes, pending binds, renewals, endorsements, and in-force policies when a moratorium is activated.

ID	Requirement
009	
BR-MOR-010	Brokers and unauthorized administrators shall not bypass an active moratorium. Any approved exception shall require delegated authority, justification, duration, scope, and audit evidence.
BR-MOR-011	Activation, extension, narrowing, supersession, and lifting shall preserve complete version history and the exact criteria applicable at each point in time.
BR-MOR-012	The system shall issue approved internal and broker communications that state the affected business, geography, peril or coverage, effective period, and permitted next steps without exposing restricted information.
BR-MOR-013	Authorized users shall view active, scheduled, expiring, and lifted moratoriums; impacted transactions; exceptions; communication status; and downstream synchronization.
BR-MOR-014	Where Duck Creek must enforce the moratorium, activation and lifting shall be synchronized and reconciled; failures shall follow an approved fail-safe policy.
BR-MOR-015	The solution shall automatically lift a moratorium at its approved expiry or require periodic reauthorization for an open-ended duration.
BR-MOR-016	All evaluations shall record the input facts, rules evaluated, determining rule, outcome, user, channel, timestamp, and correlation identifier.

7.5 Moratorium Lifecycle

14. **Initiate:** Record the event or underwriting condition, proposed scope, affected insurance activities, effective period, and issuing authority.
15. **Analyze:** Preview affected products, locations, brokers, submissions, quotes, renewals, endorsements, and in-flight transactions.
16. **Approve:** Apply delegated authority, legal/compliance review when required, and separation of duties.
17. **Activate:** Publish the effective-dated moratorium to the portal and synchronize required controls to Duck Creek.
18. **Communicate:** Issue approved internal and broker notices with scope, effective time, restrictions, and permitted next steps.
19. **Monitor:** Track suspended and referred transactions, exceptions, downstream consistency, expiry, and changing event conditions.
20. **Extend, narrow, or lift:** Require an authorized decision, update communications, remove enforcement promptly, and retain the complete history.

7.6 Conflict and Precedence Rules

Required Business Decision BHSI must approve the precedence and exception model before implementation.
 Recommended direction: when more than one moratorium applies, the most restrictive applicable rule governs unless a

specifically authorized exception has equal or higher authority. A broader catastrophe or regulatory moratorium cannot be weakened by a lower-authority rule. Every decision shall identify the moratoriums evaluated, the determining rule, and any approved exception.

8. Module 4 - Small Commercial Headless Broker Portal

8.1 Objective

Provide the complete digital intake experience for external Small Commercial brokers while integrating through APIs and controlled adapters with Duck Creek as the backend core platform. Brokers should use the portal rather than needing direct access to Duck Creek user interfaces for supported journeys.

8.2 Business Architecture Controls

- **Product configuration:** Maintain effective-dated product, state, class, coverage, question, validation, document, and authority configuration with controlled promotion across environments.
- **Submission integrity:** Use a canonical submission model, explicit lifecycle states, optimistic concurrency, autosave recovery, idempotent downstream operations, duplicate detection, and reconciliation.
- **Producer governance:** Validate appointment, license, agency authority, territory, product entitlement, and transaction authority at relevant checkpoints.
- **Underwriting workflow:** Distinguish straight-through, referral, decline, incomplete, quoted, bind-ready, bound, and failed states; preserve reasons, ownership, service targets, and broker-visible messages.
- **Documents and evidence:** Apply ACORD-aligned classification where applicable, malware scanning, metadata, versioning, retention, e-signature or consent controls where approved, and secure delivery to the authoritative repository.
- **Financial and regulatory controls:** Present only authoritative premiums, taxes, fees, forms, notices, and eligibility outcomes; require state/product compliance review before release.

8.3 End-to-End Broker Journey

Stage	Portal Responsibility
1. Access	Authenticate through Auth0 and load broker/agency/product entitlements.
2. Start	Select product or guided product discovery; create or resume a draft.
3. Customer	Search or create insured/prospect/party subject to deduplication and authority.
4. Risk Intake	Capture dynamic product, location, class, exposure, coverage, prior insurance, and loss information.
5. Controls	Evaluate product availability, moratoriums, agency authority, geographic restrictions, and required data.
6. Guidance	Use the AI guideline assistant for evidence-based informational responses.

Stage	Portal Responsibility
7. Documents	Upload ACORD forms, loss runs, schedules, photos, financials, and approved supporting documents.
8. Submit	Validate completeness and create/update the downstream submission through the Duck Creek adapter.
9. Rate / Quote	Request rating and display approved premiums, fees, taxes, coverages, limits, deductibles, conditions, and referrals.
10. Referral	Route exceptions or referrals to underwriting and track requests for information.
11. Bind / Issue	Support approved bind/issue flow only when business rules, authority, payment, documents, and downstream contracts permit.
12. Track	Display status, documents, messages, decisions, and transaction history allowed for the user.

8.4 Functional Requirements

ID	Requirement
BR-SC-001	The portal shall support configured Small Commercial products and state availability by release.
BR-SC-002	A broker shall create, save, resume, copy, and withdraw a draft within the broker's authorized scope.
BR-SC-003	Intake questions shall be dynamically driven by product, state, class, coverages, risk characteristics, and prior answers.
BR-SC-004	The portal shall capture applicant/insured, contact, agency/producer, location, classification, exposure, coverage, prior insurance, claims/loss, and required supplemental information.
BR-SC-005	The portal shall validate required fields, formats, cross-field consistency, duplicate parties/risks, and business rules before downstream submission.
BR-SC-006	The portal shall evaluate active moratoriums before configured new business, renewal, endorsement, quote, bind, issue, or coverage-change transactions.
BR-SC-007	The portal shall collect and securely transmit required documents, with type/size/content validation and malware scanning.
BR-SC-008	The portal shall create or update submissions in Duck Creek through approved APIs or services and retain correlation and downstream identifiers.
BR-SC-009	The portal shall request rating and present only the premium and rating details approved for the user's role.

ID	Requirement
BR-SC-010	The portal shall display quote versions, coverages, limits, deductibles, forms, taxes, fees, conditions, and expiration when supplied by the authoritative backend.
BR-SC-011	The portal shall route underwriting referrals and requests for information with clear status and broker notifications.
BR-SC-012	Supported bind and issue actions shall enforce authority, completeness, payment/document prerequisites, active moratoriums, and downstream validation.
BR-SC-013	Users shall view a consistent status timeline without exposing internal-only notes or restricted information.
BR-SC-014	Integration errors shall not silently duplicate submissions, quotes, parties, or policies; calls shall use idempotency and reconciliation controls.
BR-SC-015	The portal shall support role-appropriate search for drafts, submissions, quotes, and policies using approved data scopes.
BR-SC-016	The portal shall provide autosave or safe draft persistence with conflict handling and recovery from session interruption.
BR-SC-017	All material user actions and downstream transaction outcomes shall be auditable.
BR-SC-018	The solution shall support approved deep links from comparative raters while protecting state, integrity, authentication, and replay boundaries.

8.5 Product and Risk Data

Area	Illustrative Data
Applicant / Insured	Legal name, DBA, entity type, FEIN or approved identifier, years in business, contacts.
Agency / Producer	Agency, branch, producer, appointment, commissions/authority as permitted.
Locations	Address, state, county, ZIP, occupancy, construction, protection, territory data.
Classification	NAICS, SIC, class code, operations description, revenue/payroll/employees.
Coverage	Coverages, limits, deductibles, options, forms, endorsements, effective dates.
History	Prior carrier, coverage history, cancellations, claims/losses, loss runs.
Documents	ACORD, schedules, statements, photos, reports, communications.

8.6 Headless Integration Principles

- Portal APIs expose stable experience contracts rather than mirroring Duck Creek screens or internal objects.
- Adapters translate portal contracts to confirmed Duck Creek APIs/services and isolate product/version-specific differences.
- Long-running operations return trackable status and use asynchronous processing where appropriate.
- External calls use correlation IDs, timeouts, retries only when safe, idempotency, circuit breaking, and reconciliation.
- Downstream unavailability produces a clear recoverable status rather than duplicate or ambiguous transactions.
- No unsupported Duck Creek capability is assumed; each integration requires a signed contract, test environment, and ownership model.

9. Cross-Module Requirements

9.1 User Experience

- Responsive experience for approved desktop and tablet/browser combinations.
- Consistent navigation, save-state behavior, validation, error handling, notifications, and help.
- Plain-language broker messages while preserving detailed diagnostics for support users.
- Accessibility target to be approved; recommended direction is WCAG 2.2 AA for supported journeys.
- Role-aware dashboards for pending actions, drafts, referrals, holds, content tasks, and system notices.

9.2 Notifications

Event	Audience / Channel
User invitation or access change	Affected user and authorized administrator; email and in-app where applicable.
Submission status or information request	Broker and assigned internal users based on workflow.
Guideline publication or retirement	Subscribed users/content owners if required.
Moratorium activation/change/expiry	Impacted operational groups and broker users based on approved communication rules.
Integration failure requiring intervention	Support/SRE through operational alerting.

9.3 Audit

- Record actor, timestamp, action, object, before/after or version references, outcome, source channel, correlation ID, and reason when applicable.
- Protect audit records from unauthorized alteration and limit access to approved roles.
- Avoid recording credentials, tokens, secrets, full sensitive documents, or unnecessary personal data.
- Define retention, legal hold, export, and evidence requirements with compliance stakeholders.

10. Data, Integration, and API Requirements

10.1 Core Data Domains

Domain	Representative Entities
Identity and Access	User, ExternalIdentity, Organization, Agency, Producer, Role, Permission, Entitlement, Invitation, Session metadata.
Guidelines	Document, Version, Section/Chunk, Metadata, Approval, Publication, Citation, Query, Response, Feedback.
Moratorium	Moratorium, BusinessActivity, LineOfBusiness, Product, Geography, Peril, Coverage, RiskCriteria, Agency/Producer Scope, EffectivePeriod, Approval, Activation, Evaluation, Exception, Communication, Lifting, and AuditEvent.
Submission	Draft, Applicant, Party, Location, Exposure, Coverage, Questionnaire, Document, Submission, Quote, Referral, Policy reference.
Integration / Operations	OutboxMessage, IntegrationOperation, Retry, Reconciliation, Error, AuditEvent, Notification.

10.2 Source-of-Truth Direction

Data	Proposed Authority	Decision
Credentials and external authentication	Auth0 / federated IdP	Confirm IAM design.
Portal roles and experience permissions	Portal authorization service	Recommended; confirm governance.
Broker/agency/producer master	Duck Creek or enterprise master data	Open.
Core submission, quote, policy transaction	Duck Creek	Confirm per product and transaction.
Guideline content and publication	Approved portal content repository	Confirm content governance.
Moratorium master	Portal or approved enterprise control service	Open; downstream synchronization may be required.
Portal interaction and audit metadata	Portal operational/audit stores	Confirm retention and access.

10.3 API Standards

- Versioned REST/JSON contracts unless another enterprise standard is approved.
- OAuth/JWT protection, scopes, server-side resource authorization, and least privilege.
- Consistent validation and Problem Details-style errors with correlation IDs.
- Idempotency keys for retry-sensitive writes and explicit concurrency/version checks.
- Pagination, filtering, sorting, rate limits, timeouts, and payload limits.
- No stack traces, secrets, internal identifiers, or restricted data in end-user error responses.
- Contract tests and backward-compatibility governance for portal and Duck Creek adapters.

11. Non-Functional Requirements

Approval Required Numerical targets are proposed baselines and must be validated through production-volume modeling, downstream dependency analysis, security review, and business approval.

ID	Area	Proposed Requirement
NFR-001	Availability	Target 99.9% monthly availability for production portal, excluding approved maintenance; dependency impact defined separately.
NFR-002	Performance	Define p95 targets for login, page load, search, chatbot response, submission save, and synchronous integration calls.
NFR-003	Scalability	Support expected users, agencies, products, content volume, concurrent sessions, question volume, and catastrophe-event peaks.
NFR-004	Security	TLS, secure headers, CSP, strict CORS, secret management, dependency scanning, SAST/DAST, file scanning, and least privilege.
NFR-005	Privacy	Data minimization, classification, consent/notice where required, retention, deletion, and restricted support access.
NFR-006	Accessibility	Recommended WCAG 2.2 AA for supported journeys, subject to approval.
NFR-007	Resilience	Timeouts, circuit breakers, safe retries, idempotency, outbox processing, reconciliation, and graceful degradation.
NFR-008	Recovery	RTO/RPO approved by data classification and business criticality before UAT.
NFR-009	Observability	Structured logs, metrics, traces, audit events, dashboards, alerting, and end-to-end correlation.
NFR-010	Maintainability	Modular architecture, automated tests, code quality gates, documentation, and controlled configuration.

ID	Area	Proposed Requirement
NFR-011	Compatibility	Approved browser, device, file-format, and assistive-technology matrix.
NFR-012	AI Safety	Grounding, citation checks, content access controls, prompt-injection defenses, evaluation, human escalation, and rollback.

12. Reporting, Audit, and Operations

12.1 Business Reporting

- Broker adoption, login success/failure, invitations, deactivations, and organization onboarding.
- Guideline questions by product/topic, unanswered questions, citation usage, feedback, and content gaps.
- Active, scheduled, expiring, and lifted moratoriums; suspended or referred transactions; exceptions; impacted products, coverages, agencies, and geographies; and evaluation trends.
- Drafts, submission conversion, completeness, referral rate, quote outcomes, cycle time, and downstream failures where data is available and approved.

12.2 Operational Dashboards

- Auth0 and identity provisioning status.
- Duck Creek adapter latency, errors, queue depth, retries, reconciliation, and dead-letter conditions.
- Document ingestion and AI indexing status.
- Moratorium publication and downstream synchronization status.
- Application/API health, database health, capacity, security alerts, and release/version information.

12.3 Support Requirements

- Tiered support model and ownership matrix.
- Runbooks for login failure, provisioning mismatch, stuck submission, duplicate prevention, AI content issue, incorrect moratorium evaluation, activation or lifting failure, and downstream outage.
- Safe support tools using delegated access, reason capture, and audit.
- Incident severity, escalation, communications, and post-incident review procedures.

13. Acceptance, Traceability, and Delivery

13.1 Definition of Ready

- Business process and persona approved.
- Requirement and acceptance criteria reviewed.
- Data classification and source-of-truth identified.
- Duck Creek/Auth0/AI integration contract and environment available or an approved mock contract exists.
- Security, privacy, accessibility, audit, and operational requirements identified.
- Test data and dependency owners assigned.

13.2 Definition of Done

- Functional and negative-path acceptance criteria pass.
- Unit, integration, contract, end-to-end, security, accessibility, and performance tests meet approved gates.
- Audit, telemetry, dashboards, alerts, support runbooks, and reconciliation are operational.
- No unresolved critical/high security findings at release approval.
- Business, product, architecture, security, data, operations, and Duck Creek owners approve applicable release evidence.

13.3 Recommended Delivery Increments

Increment	Outcome
0. Discovery and Governance	Validated journeys, source-of-truth, integration contracts, security/AI governance, and release scope.
1. Platform and Identity	Angular/.NET foundation, Auth0 login, portal authorization, user lifecycle, audit, CI/CD baseline.
2. Guideline Content and Search	Secure content ingestion, metadata, search, versions, approval/publication.
3. AI Guideline Assistant	Grounded Q&A, citations, refusal/escalation, feedback, evaluation, monitoring.
4. Moratorium Controls	Moratorium scope model, approval, activation, Allow/Suspend/Refer evaluation, portal enforcement, communications, lifting, reporting, and Duck Creek reconciliation.
5. Small Commercial Intake MVP	Draft, dynamic intake, validation, documents, submission/status integration.
6. Rating, Quote, and Referral	Rating contracts, quote display/versioning, referrals, notifications.
7. Bind/Issue and Operational Hardening	Approved final transactions, resiliency, DR, performance, UAT, production readiness.

14. Assumptions, Dependencies, Risks, and Open Decisions

14.1 Key Assumptions

- Angular, ASP.NET Core, SQL Server, and Auth0 remain the approved direction.
- The portal can begin with modular boundaries in one primary application/deployment model and evolve when justified.
- Duck Creek remains the backend core platform for approved products and transactions.
- Business owners will provide authoritative guideline content, applicability metadata, and approval ownership.
- Business Operations and Underwriting will define moratorium authority, affected insurance activities, scope criteria, precedence, exception rules, treatment of in-flight and existing business, review cadence, communications, and lifting criteria.

14.2 Dependencies and Risks

ID	Risk / Dependency	Required Mitigation
R-001	Duck Creek APIs, environments, authentication, contracts, or rate limits are unknown.	Complete integration discovery and contract tests before commitment.
R-002	Identity or entitlement synchronization becomes stale.	Define authority, event/reconciliation model, revocation, and fail-safe behavior.
R-003	AI returns unsupported or outdated guidance.	Approved content lifecycle, citations, evaluation, refusal, monitoring, and escalation.
R-004	Incorrect moratorium scope, delayed activation or lifting, or inconsistent Duck Creek synchronization permits prohibited activity or unnecessarily blocks permitted business.	Precise activity and territorial scope, impact preview, deterministic precedence, synchronized enforcement, fail-safe behavior, expiry monitoring, and reconciliation.
R-005	Headless workflow duplicates or loses downstream transactions.	Idempotency, correlation, state machine, retries, and reconciliation.
R-006	Sensitive guideline or broker data is exposed.	Access filtering, secure retrieval, data minimization, testing, and monitoring.
R-007	Catastrophe event causes traffic spikes.	Capacity modeling, load testing, caching where safe, scaling, and operational playbooks.
R-008	Scope expands to all policy lifecycle transactions in MVP.	Release-based product and transaction scope with explicit change control.

14.3 Open Decisions

ID	Decision Needed
OD-001	Which Small Commercial products, states, transaction stages, and user personas are in the first release?
OD-002	Which Duck Creek products and versions are used, and what APIs/services are approved?
OD-003	What is the authoritative source for broker, agency, producer, appointments, roles, and product entitlements?
OD-004	Which Auth0 tenant, organization, connection, MFA, session, logout, invitation, and domain-routing policies apply?
OD-005	Which AI model, search/vector service, document repository, moderation, and retention services are approved?

ID	Decision Needed
OD-006	Who approves guideline content, and how are effective dates, supersession, state/product applicability, and emergency corrections governed?
OD-007	Where will the authoritative moratorium record be maintained, how will activation and lifting be synchronized to Duck Creek, and what fail-safe behavior applies during an outage?
OD-008	Which insurance activities may be suspended; what product, geography, peril, coverage, and distribution criteria are supported; how are in-flight and in-force business treated; and what precedence, exception authority, broker messaging, review cadence, and lifting criteria are approved?
OD-009	Which rating, quote, referral, bind, issue, document, and payment journeys are available through Duck Creek?
OD-010	What approved NFR volumes, SLAs/SLOs, RTO/RPO, retention, and support hours apply?

Appendix A - Glossary

Term	Definition
Auth0	Identity platform used as the authentication and federation layer, subject to approved tenant and security configuration.
SSO	Single Sign-On.
OIDC	OpenID Connect, an identity layer used with OAuth 2.0.
JWT	JSON Web Token used to convey signed access claims; authorization must still be enforced by the API.
Headless	An approach where the custom portal owns the user experience and integrates with backend core capabilities through APIs/services rather than backend screens.
RAG	Retrieval-Augmented Generation, where relevant approved content is retrieved and supplied to a generative model to produce a grounded answer.
Moratorium	A temporary, formally authorized suspension of specified insurance-writing activity for a defined scope and period. It may apply to new business, renewals, endorsements, quotes, binding, policy issuance, or selected coverages—for example, a Florida Homeowners moratorium due to a hurricane or an underwriting moratorium for wildfire-exposed regions.
System of Engagement	The portal layer through which users perform supported journeys.

Term	Definition
System of Record	The authoritative platform for approved core transaction data, expected to be Duck Creek for applicable insurance transactions.
Idempotency	A control ensuring safe repetition of a request does not create unintended duplicate results.

Appendix B - Source Notes

This consolidated document was prepared from the project requirements supplied in this conversation and the following internal working materials:

- Broker Portal Project Initiation Package, working draft dated September 22, 2026. It identifies Angular, ASP.NET Core, SQL Server, Auth0, backend-enforced authorization, Duck Creek integration adapters, operations, security, and phased delivery as the current direction.
- Discussion on SSO Authentication & Other Requirements. It documents the Small Commercial platform context, Auth0 identity aggregation, external broker access, user provisioning, secured underwriting guidelines, Angular/C# technology direction, and a future moratorium management capability.

Important: References to future Duck Creek, Auth0, AI, enterprise platform, or external broker capabilities remain requirements or proposed design directions until validated with system owners and approved contracts.